

Festo Smart Factory Lab - ICS Security Assessment

Network Security Assessment Team

June 11, 2026

1 Executive Summary

This assessment evaluates the security posture of the Festo Smart Factory Lab OT/ICS network. The lab comprises six manufacturing stations (conveyor, sorting, camera inspection, magazine, press, oven) plus a robot arm cell, interconnected through Siemens S7-1500 PLCs, Festo CPX controllers, MTP700 HMIs, and a centralised MES PC.

The assessment is based on passive packet capture analysis (5 captures, 55,000 frames), active DCP Identify-All output (14 devices), and nmap host discovery (21 live hosts across 172.21.0.0/18).

Table 1: Assessment Scope Key Findings

Assessment Scope	Key Finding
Network segmentation	NONE — fully flat /18 subnet
PLC access control	NONE — all PLCs reachable from any host
MES / OT separation	NONE — MES PC shares subnet with PLCs
Engineering access control	NONE — uncontrolled, incl. unregistered devices
Unaccounted assets	6+ devices not in original inventory
Wireless / external exposure	TP-Link AP present on OT subnet

The overall security posture is assessed as **CRITICAL**. The network presents no meaningful barrier between IT systems, engineering workstations, visitor devices, and live industrial control equipment. A single compromised host on the subnet has unrestricted access to all PLCs and HMIs.

2 Regulatory and Standards Alignment

2.1 IEC 62443 Violations

Table 2: IEC 62443 Violations

Security Issue Found	Standard Violated
No zones or conduits — entire network is one implicit zone with no conduit controls	IEC 62443-1-1 (Zone & Conduit Model)
Incomplete asset inventory (6+ undocumented devices during active operation)	IEC 62443-2-1 (CSMS — Asset Inventory)
No authentication on PLC web servers or PROFINET	IEC 62443-3-3 / SR 1.1 (Human User Identification & Authentication)
No controlled access path for remote engineering	IEC 62443-3-3 / SR 2.6 (Remote Session Termination)
No network segmentation or zone boundary protection	IEC 62443-3-3 / SR 5.1 & SR 5.2 (Network Segmentation & Zone Boundary Protection)

Table 3: ISO/IEC 27001 Violations

Security Issue Found	Standard Violated
Six devices absent from inventory, including one actively programming PLCs via S7comm (172.21.0.156)	Clause 8.1 / Annex A.8 (Asset Management)
Flat /18 subnet with no separation between services, users, or systems	Annex A.8.22 (Network Segmentation)
No firewall, ACL, or VLAN between MES-level and field-level devices	Annex A.8.20 (Network Security)

2.2 ISO/IEC 27001 Violations

2.3 NIS2 Directive Violations

Table 4: NIS2 Directive Violations

Security Issue Found	Standard Violated
No network segmentation, access control, or asset management in lab network	Article 21 — Cybersecurity Risk Management
Devices from multiple vendors (Siemens, Festo, Turck, SensoPart, TP-Link) with unknown/unverified firmware	Article 21(2)(e) — Supply Chain Security
Visitor/external laptop (Kyan_laptop, a0:ce:c8:f7:ab:c9) on live OT subnet — no network admission controls	Article 21(2)(h) — Basic Cyber Hygiene & Training

2.4 Defense-in-Depth Violations

Table 5: Defense-in-Depth Violations

Security Issue Found	Standard Violated
Only one perimeter exists (edge of /18 subnet) — no segmentation between IT and OT	Defense-in-Depth — Multiple Independent Controls
No DMZ or IDMZ between MES and field layers	Defense-in-Depth — Layered Architecture
No per-PLC firewall or ACL	Defense-in-Depth — Compartmentalization
No authentication on PROFINET, S7comm, or PLC web servers	Defense-in-Depth — Authentication Layer
Single perimeter breach allows unrestricted lateral movement to all PLCs	Defense-in-Depth — No Fallback Controls

2.5 Least Privilege & Zero Trust Violations

3 Network Identification

3.1 Observed Topology

The entire lab operates on a single flat subnet: **172.21.0.0/18** (broadcast 172.21.63.255, gateway 172.21.0.230). No VLANs, no firewall zones, and no routing boundaries were observed between any device classes. All hosts - from the MES PC to individual PLCs and HMIs - share the same Layer 2 broadcast domain.

Table 6: Least Privilege & Zero Trust Violations

Security Issue Found	Standard Violated
MES PC (172.21.0.90) can reach every other PLC, not just the one it needs (PLC S2)	Least Privilege — Only Necessary Access
MES PC is reachable from PLCs via NTP and can poll HMIs unnecessarily	Least Privilege — Unrestricted Bidirectional Access
Engineering PCs have persistent S7comm access instead of only during programming windows	Least Privilege — Continuous Unnecessary Access
PC Cobot-ML (172.21.1.90) can reach PLCs S1, S3–S6 despite needing only OPC-UA to PLC S2	Least Privilege — Default Deny / Explicit Allow
Every device trusts every other device based on subnet membership, not verified identity or role	Zero Trust — No Implicit Trust Based on Network Location

Table 7: OT Network Devices

Device	IP	Type	Notes
PLC S1–S6	172.21.x.1	Siemens S7-1500 PLCs	Process controllers, each exposing HTTP/80, OPC-UA/4840, S7comm/102, PROFINET
HMI S1–S6	172.21.x.10	Siemens MTP700	Operator panels, PROFINET
Robot Arm	172.21.1.40	Universal Robots UR3e	Cobot, firmware unconfirmed
rfdboxcobot	172.21.1.20	Turck TBEN-S2-2RFID	RFID reader, PROFINET
Sensor S3	172.21.3.50	SensoPart	Vision sensor, HTTP
ET200SP IO S2	172.21.2.100	Siemens IM155-6PN/2 HF	PROFINET IO device, FW V4.2.4
CPX Controller S2	172.21.2.60	Festo CPX	Protocol unconfirmed
CPX Controller S6	172.21.6.60	Festo CPX	PROFINET RT cyclic confirmed (UDP 1740–1743)
Power Monitor S2	172.21.2.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed
Power Monitor S6	172.21.6.61	Siemens (10:DF:FC OUI)	Protocol unconfirmed

3.2 OT Network

3.3 IT / MES Network

Table 8: IT / MES Network Devices

Device	IP	Role	Notes
festo-mes-pc	172.21.0.90	MES / NTP Server	Polls PLC S2 alarm table every ~3 s; NTP master; OPC-UA client to PLC S2
desktop-6jd9ili	172.21.0.168 / .192	Engineering PC (dual-NIC)	SIMATIC-PC family; TIA Portal host presumed
gebruik-tt8ke80	172.21.0.165	VMware Host	Two MACs: physical NIC (60:cf:84) + VMware vNIC (00:0c:29); VM roles unknown
PC Cobot-ML	172.21.1.90	ML Inference PC	OPC-UA client to PLC S2
CPX-IOT	172.21.0.210	Unknown / MQTT?	Festo device; silent during all captures — cloud link unconfirmed

3.4 Engineering Access

At least three distinct engineering/programming channels were observed or inferred, none of which pass through any controlled access path:

- **desktop-6jd9ili** (172.21.0.168 / 172.21.0.192): Registered engineering PC with dual NICs. Presumed TIA Portal host.
- **172.21.0.156** (MAC c4:c6:e6:d4:c3:81): Unregistered device. Maintained a persistent S7comm/102 session to PLC S2 across all five captures. Consistent with TIA Portal or Step 7 in online monitoring mode. This device is not in any inventory version.
- **Kyan_laptop** (172.21.0.179, MAC a0:ce:c8:f7:ab:c9): Identified by DCP as SIMATIC-PC family. Likely a student or visitor machine admitted to the OT subnet without restriction.

3.5 External & Cloud Connections

Two devices raise concerns about external connectivity:

- **TP-Link device** (172.21.0.200): Identified via UPnP SSDP as a TP-Link access point or router (MiniUPnPd/1.8). Broadcasts on TP-Link proprietary discovery port UDP/20002. If this device

has a WAN port or wireless interface bridged to the OT subnet, it represents a direct internet-facing exposure.

- **CPX-IOT** (172.21.0.210): Festo device, OUI 00:0E:F0. Produced zero traffic in all five captures. The name ‘IOT’ and the CPX product line’s known cloud connectivity features suggest it may be a cloud gateway (MQTT over internet). Its silence during captures could indicate an idle state or encrypted tunnelled traffic not visible at Layer 2.

3.6 Flat vs. Segmented Assessment

The network is entirely flat. There is no evidence of any segmentation mechanism:

- No VLANs (capture1 shows VLAN tag value 0 = untagged/priority-tagged only on the PROFINET cyclic traffic, not a segmentation VLAN)
- No routed boundaries between device classes
- No firewall between MES and PLCs
- No DMZ or IDMZ between IT and OT layers
- No 802.1X or MAC-based port security on any observed switch

From a Purdue Model / IEC 62443 zone perspective: the network presents as a single undifferentiated zone spanning Levels 0 through 3, with potential Level 4 exposure via the TP-Link device and CPX-IOT.

4 Security Weaknesses

Findings are rated CRITICAL / HIGH / MEDIUM / LOW based on exploitability and potential impact on process availability, safety, and data integrity.

Table 9: Security Weaknesses Summary

ID	Severity	Finding
F-01	CRITICAL	Fully flat /18 network - no zone or conduit separation
F-02	CRITICAL	PLCs directly reachable from all hosts - no access control
F-03	CRITICAL	MES PC has unrestricted protocol access to all OT devices
F-04	CRITICAL	Unregistered device actively programming PLCs via S7comm
F-05	HIGH	PLC web servers expose HTTP (plaintext) on the OT subnet
F-06	HIGH	OPC-UA servers on PLCs accessible network-wide with no observed auth
F-07	HIGH	TP-Link AP present on OT subnet - potential wireless attack surface
F-08	HIGH	Visitor/unvetted laptop (Kyan_laptop) on live OT network
F-09	HIGH	gebruik-tt8ke80 runs VMware with unknown VM roles on OT subnet
F-10	MEDIUM	CPX-IOT cloud gateway: function and traffic unconfirmed
F-11	MEDIUM	PROFINET carries no authentication - DCP allows rename/reconfigure
F-12	MEDIUM	Power monitor and CPX controller protocols unconfirmed
F-13	MEDIUM	Robot arm firmware version unverified
F-14	LOW	NTP synchronisation provided by MES PC - single point of failure

Standard Ref	IEC 62443-1-1 (Zone & Conduit model) · IEC 62443-3-3 SR 5.1, SR 5.2 · ISO/IEC 27001 A.8.22 · NIS2 Art. 21
Observation	All 21+ live hosts share 172.21.0.0/18 with no VLAN, no routed boundary, and no firewall between device classes. PLCs (Level 1/2), HMIs (Level 2), MES (Level 3), engineering PCs, visitor laptops, and infrastructure devices are on one broadcast domain.
Impact	Any compromised or malicious host has Layer 3 reachability to every PLC, HMI, and sensor. Lateral movement from an infected engineering laptop to all six PLCs requires no exploitation of additional controls - there are none.
Recommendation	Implement a Purdue Model segmentation: Level 0/1 (field), Level 2 (control/HMI), Level 3 (MES), separated by firewalls or managed switch ACLs with an IDMZ between Levels 2 and 3. Each station subnet (172.21.x.0/24) should be a discrete security zone.
Standard Ref	IEC 62443-3-3 SR 1.1, SR 1.2, SR 5.1 · Defense-in-Depth · Least Privilege
Observation	All S7-1500 PLCs expose HTTP/80 (web server), OPC-UA/4840, and S7comm/102 simultaneously to the entire subnet. Confirmed by TCP conversation analysis across all captures. No authentication was observed at the network layer for any of these services.
Impact	An attacker on any host in the /18 can connect to any PLC's S7comm port, issue read/write requests to process data, download or upload program blocks, or force a CPU STOP - without needing any credentials. All six production stations are simultaneously vulnerable from a single entry point.
Recommendation	Apply PLC-level access controls: (1) Disable unused services (HTTP web server if not required for operations). (2) Enable TIA Portal's 'Know-How Protection' and CPU access protection. (3) Restrict S7comm/102 and OPC-UA/4840 to specific source IPs via firewall ACL. Engineering S7comm access should only be permitted from the engineering VLAN during active maintenance windows.
Standard Ref	IEC 62443-2-1 (CSMS) · IEC 62443-3-3 SR 5.2 · ISO/IEC 27001 A.8.22 · Purdue Model Level 3 / Level 2 boundary
Observation	festo-mes-pc (172.21.0.90) communicates directly with PLC S2 via HTTP (alarm polling), OPC-UA (process data), and NTP - all unmediated, with no DMZ or proxy. The MES and HMI S2 also exchange NTP directly.
Impact	The MES PC is a Windows-based SIMATIC-PC system and the most likely target for phishing, software supply-chain, or remote-access attacks. Compromise of the MES PC gives an attacker an already-trusted, persistent connection to PLC S2's control interface. Conversely, a malformed PLC response could exploit vulnerabilities in the MES software.
Recommendation	Introduce an IDMZ (Industrial DMZ) between the MES and the OT layer. Only specific, validated protocols should traverse the IDMZ in defined directions: historian replication should be unidirectional (OT→IT only, via a data diode or enforced one-way gateway). Alarm polling from MES to PLC should be proxied through an application-layer gateway rather than a direct TCP session.

- 4.1 F-01 - CRITICAL: Fully Flat /18 Network
- 4.2 F-02 - CRITICAL: Unrestricted PLC Access
- 4.3 F-03 - CRITICAL: No MES / OT Separation
- 4.4 F-04 - CRITICAL: Unregistered Device Programming PLCs
- 4.5 F-05 - HIGH: PLC HTTP Web Servers (Plaintext)
- 4.6 F-06 - HIGH: OPC-UA Accessible Network-Wide
- 4.7 F-07 - HIGH: TP-Link Access Point on OT Subnet
- 4.8 F-08 - HIGH: Visitor/Unvetted Laptop on OT Network
- 4.9 F-09 - HIGH: VMware Host with Unknown VM Roles
- 4.10 F-10 through F-15 - Medium / Low Findings

Standard Ref	IEC 62443-2-1 (Asset Management / Change Control) · ISO/IEC 27001 A.8.1, A.8.19 · Zero Trust
Observation	IP 172.21.0.156 (MAC c4:c6:e6:d4:c3:81, OUI unresolved) maintained a persistent, high-volume S7comm session to PLC S2 across all five capture files. This device appears in no version of the asset inventory. Its behaviour is consistent with TIA Portal in online monitoring or active programming mode.
Impact	An unidentified device with S7comm write access to a live PLC represents a rogue programmer scenario. If this device is compromised or malicious, it can alter PLC logic, inject faults, or cause unsafe states on Station 2 without any audit trail. Its absence from the inventory means no baseline behaviour exists against which to detect anomalies.
Recommendation	Immediately identify this device physically. Cross-reference the MAC with switch port tables. If it is a legitimate engineering station, add it to the inventory and bring it under change control. If it cannot be accounted for, treat as an incident. Engineering access to PLCs should require 802.1X authentication and be logged; S7comm should be blocked at the network layer outside authorised programming windows.

Standard Ref	IEC 62443-3-3 SR 1.3 (Authenticator Management) · Defense-in-Depth
Observation	PLC S2 serves HTTP on port 80. The MES PC issues unauthenticated GET requests to /ClientArea/AlarmTable.mwsl approximately every 3 seconds. No TLS/HTTPS was observed. The same HTTP web server capability is present on all S7-1500 PLCs.
Impact	Alarm and diagnostic data is transmitted in plaintext and can be intercepted or spoofed by any host on the subnet. The web server also provides a browser-accessible interface to PLC diagnostics that any subnet host can reach without authentication.
Recommendation	If the PLC web server is used operationally: (1) Enable HTTPS in TIA Portal PLC properties. (2) Enable access control / user authentication on the web server. (3) Restrict HTTP/HTTPS access to the MES PC IP only via firewall ACL. If the web server is not required, disable it entirely in TIA Portal.

Standard Ref	IEC 62443-3-3 SR 1.1 · Least Privilege · Zero Trust
Observation	OPC-UA port 4840 on PLC S2 receives connections from both 172.21.0.90 (MES PC) and 172.21.1.90 (PC Cobot-ML). No certificate-based authentication or SecurityPolicy enforcement was verifiable from packet analysis. OPC-UA is likely running in 'None' security mode, which is the S7-1500 default without explicit TIA Portal configuration.
Impact	Any host on the /18 subnet can connect to the OPC-UA server and read/write process variables, depending on the server's address space configuration. OPC-UA with no security mode provides no protection against eavesdropping, tampering, or replay attacks.
Recommendation	Configure OPC-UA to use SecurityMode=SignAndEncrypt with Basic256Sha256 or better. Deploy client certificates and enforce server-side certificate validation. Firewall OPC-UA/4840 to authorised client IPs only.

Standard Ref	NIS2 Art. 21 · IEC 62443-2-1 · Defense-in-Depth
Observation	172.21.0.200 (MAC 20:23:51:41:a2:88) was identified via UPnP SSDP as a TP-Link device running MiniUPnPd. It broadcasts on UDP/20002 (TP-Link proprietary management). If this device has a wireless interface bridged or NATted to the OT subnet, the physical perimeter of the lab network is effectively removed.
Impact	A wireless interface on the OT subnet enables attacks from outside the lab without physical access. Even if the wireless is WPA2-protected, consumer-grade TP-Link firmware has a poor security patching record and a history of CVEs. Critically, MiniUPnPd is an internet-facing port-forwarding daemon - it may be exposing OT services externally.
Recommendation	Remove the TP-Link device from the OT subnet immediately or isolate it on a separate management VLAN with no OT reachability. Audit the device's WAN/port-forwarding configuration. If internet access is required in the lab for administrative purposes, it must traverse a firewall on a separate IT network segment.

Standard Ref	NIS2 Art. 21(2)(h) · IEC 62443-2-1 (Access Management) · Zero Trust
Observation	Kyan_laptop (172.21.0.179, MAC a0:ce:c8:f7:ab:c9) was identified by DCP scan as a SIMATIC-PC family device - indicating it has PROFINET network drivers installed, consistent with a student or lab visitor who has configured their laptop for PROFINET work. It was admitted to the live OT subnet without apparent restriction.
Impact	A personal or student laptop is far more likely to carry malware, have unpatched software, or be used outside the lab on untrusted networks than a managed workstation. Once on the OT subnet, it has the same access to PLCs as any other device.
Recommendation	Implement network admission control (802.1X or MAC allowlisting on the lab switches). Visitor/student devices should only access a dedicated quarantine VLAN with no OT reachability. If PROFINET access is needed for lab exercises, use a dedicated lab PC, not personal devices.

Standard Ref	ISO/IEC 27001 A.8.1 (Asset Management) · IEC 62443-2-1 · Defense-in-Depth
Observation	gebruik-tt8ke80 (172.21.0.165) presents two MACs at the same IP: 60:cf:84:d1:d0:d5 (physical NIC) and 00:0c:29:63:ba:59 (VMware virtual NIC, OUI confirmed). The roles and OS of hosted VMs are unknown. VMs with bridged networking inherit OT subnet membership.
Impact	If any VM is internet-connected or runs unpatched software, it provides a path from an untrusted environment to the OT subnet. Hypervisor vulnerabilities can also enable VM escape to the host, which has physical-layer OT access. Unknown VMs cannot be patched or monitored.
Recommendation	Document all VMs on this host. Determine whether any VM has internet connectivity and isolate it from OT. Consider whether VMware is appropriate on the OT subnet; if virtualisation is needed, use a hypervisor specifically evaluated for OT contexts.

Table 10: Medium and Low Severity Findings

ID	Sev.	Recommendation Summary
F-10	MEDIUM	Determine if CPX-IOT has internet connectivity. If so, place behind a dedicated firewall with strict egress rules. Audit any cloud credentials stored on the device.
F-11	MEDIUM	Restrict PROFINET (Layer 2, EtherType 0x8892) to known switch ports via VLAN and port security. Disable DCP Set capability on production devices in TIA Portal if supported.
F-12	MEDIUM	Perform targeted protocol analysis (Modbus/502, IO-Link, REST) to characterise attack surface. Until confirmed, treat as unexposed and restrict to their station subnets.
F-13	MEDIUM	Access the UR Polyscope web interface to confirm firmware version. Apply latest UR firmware updates. Restrict UR Robot port 29999 (dashboard) and 30001-30004 (streaming) to authorised hosts only.
F-14	LOW	Add a secondary NTP source (hardware GPS clock or secondary server). Authenticate NTP with NTS or MD5 keys between the MES PC and PLCs.
F-15	LOW	Cross-reference MAC addresses with switch ARP tables and physically trace cables. Devices that cannot be identified should be removed from the network until documented.

Table 11: Standards Compliance Summary

Standard / Requirement	Requirement Summary	Current Status	Findings
IEC 62443-1-1 Zone & Conduit	Define security zones; control conduits between zones	NOT MET - single flat zone	F-01, F-02, F-03
IEC 62443-2-1 CSMS	Asset inventory, risk assessment, access management, change control	PARTIAL - incomplete inventory, no documented procedures evident	F-04, F-09, F-15
IEC 62443-3-3 SR 5.1 / 5.2	Network segmentation; zone boundary protection	NOT MET	F-01, F-02, F-03
IEC 62443-3-3 SR 1.1 / 1.2	Human user identification; device authentication	NOT MET - no auth on S7comm, HTTP, or PROFINET	F-02, F-05, F-06, F-11
ISO/IEC 27001 A.8.1 Asset Mgmt	Complete, maintained asset register	PARTIAL - 6+ devices absent from inventory	F-04, F-09, F-15
ISO/IEC 27001 A.8.22 Segmentation	Separate groups of services and users	NOT MET	F-01
NIS2 Art. 21 Risk Management	Segmentation, access control, asset management	NOT MET in all three areas	F-01-F-09
NIS2 Art. 21(2)(e) Supply Chain	Manage vendor/software supply chain risk	NOT MET - unverified firmware across multiple vendors	F-10, F-13
Defense-in-Depth	Multiple independent security layers	NOT MET - single perimeter only	F-01-F-04
Least Privilege	Minimum necessary access per component	NOT MET - all devices have unrestricted subnet access	F-02, F-03, F-06
Zero Trust	No implicit trust from network location	NOT MET - trust granted by /18 membership	F-02, F-04, F-08